

Sindrome ReNU Italia APS

Relazione Tecnica per il DPO

Impostazione giuridica Cloudflare & Funzione sendEmail/Resend

Data: 24 September 2026 · Versione 1.0 · Documento riservato

A:	DPO — Sindrome ReNU Italia APS
Da:	Responsabile Tecnico del Sito
Oggetto:	Risposta ai quesiti tecnici DPO (quesiti 1 e 2)
Data:	24 September 2026
Rif.:	Sito web www.sindromerenu.it — stack tecnologico Cloudflare + Resend

❶ QUESITO 1 — Impostazione giuridica adottata per Cloudflare

1.1 Servizi Cloudflare attivi per il sito

Il sito www.sindromerenu.it è interamente basato su infrastruttura Cloudflare. I servizi attivi e la loro funzione sono i seguenti:

Servizio	Funzione tecnica	Dati personali coinvolti
Cloudflare Pages	Hosting e distribuzione globale del sito web (CDN edge)	IP visitatori, header HTTP (trattati autonomamente da CF)
Cloudflare Workers	Runtime edge per il framework Hono (SSR): gestisce ogni richiesta HTTP	Tutti i dati in transito (form, API, query)
Cloudflare D1	Database SQLite distribuito: archivia contatti, iscrizioni, storie, donazioni	Dati personali degli interessati (nome, email, CF, messaggio, ip_hash)

1.2 Impostazione giuridica attuale — Titolare Autonomo

La Privacy Policy attualmente pubblicata su www.sindromerenu.it qualifica Cloudflare, Inc. come **Titolare Autonomo del Trattamento** — non come Responsabile del Trattamento ex art. 28 GDPR. Questa scelta è stata adottata per i servizi di CDN/Pages/Workers, dove Cloudflare elabora dati tecnici (IP, header HTTP, dati di routing) nell'ambito dei propri servizi di sicurezza e infrastruttura, per finalità proprie (protezione DDoS, bot management, analytics di rete), senza che l'Associazione possa impartire istruzioni specifiche su tali trattamenti.

Testo esatto dalla Privacy Policy pubblicata:

"I trasferimenti verso Cloudflare Inc. (USA) sono leciti in base all'adesione di Cloudflare all'EU-US Data Privacy Framework (Decisione di adeguatezza della Commissione Europea 2023/1795 del 10 luglio 2023) — base giuridica autonoma e sufficiente ai sensi dell'Art. 45 GDPR, che non richiede Clausole Contrattuali Standard."

1.3 Base giuridica del trasferimento verso USA — DPF confermato

Cloudflare, Inc. è certificata nell'**EU-US Data Privacy Framework (DPF)**, Decisione di adeguatezza della Commissione Europea n. 2023/1795 del 10 luglio 2023. Il DPF è confermato attivo a settembre 2026. La certificazione è verificabile direttamente sul registro ufficiale del Dipartimento del Commercio USA:

Soggetto	Stato DPF	Registro ufficiale	Versione DPA
Cloudflare, Inc.	■ CERTIFICATA — Attiva	dataprivacyframework.gov/participa nt/5666	v6.4 — 3 aprile 2026

Il DPA Cloudflare v6.4 (efficace dal 3 aprile 2026) include inoltre, a titolo di salvaguardia aggiuntiva, le **Clausole Contrattuali Standard (SCC)** ex Decisione della Commissione Europea 2021/914 del 4 giugno 2021 (Modulo 2 — Controller→Processor e Modulo 3 — Processor→Sub-Processor), nonché il **UK Addendum** e le modifiche per la Svizzera. Il trasferimento verso USA è quindi lecito su base autonoma DPF (art. 45 GDPR), con SCC come salvaguardia alternativa (art. 46 GDPR).

1.4 Questione aperta: Cloudflare D1 e qualificazione come Responsabile

■ Osservazione per il DPO

Cloudflare D1 è il database che archivia i dati personali degli interessati (nome, cognome, email, codice fiscale, messaggio, hash IP). A differenza dei servizi CDN/Pages (dove Cloudflare tratta dati tecnici per finalità proprie), per D1 Cloudflare elabora dati su esplicite istruzioni dell'Associazione, che ne determina finalità e mezzi del trattamento.

Per D1 potrebbe essere più corretta la qualificazione di Cloudflare come **Responsabile del Trattamento ex art. 28 GDPR**, anziché come titolare autonomo.

Il DPA Cloudflare v6.4 è già predisposto per questa qualificazione (art. 2.3: "the Customer is the Controller, and Cloudflare is a Processor") ed è disponibile self-service sulla dashboard Cloudflare. La sottoscrizione non richiede negoziazioni: il DPA è pre-firmato da Cloudflare e accettabile digitalmente.

1.5 Misure di sicurezza Cloudflare (per valutazione art. 32 GDPR)

Il DPA Cloudflare v6.4, Annex 2, elenca le misure tecniche e organizzative implementate (ISO/IEC 27000, SOC 2 Type II, PCI DSS Level 1). Le principali:

Misura	Dettaglio
Cifratura dati in transito	TLS 1.3+, AES-128/256, RSA-2048+/ECC-256+
Cifratura dati a riposo	AES-XTS 128-bit o superiore su tutti i dischi
Controllo accessi	Zero-trust, MFA con hard token fisici, principio least-privilege
Audit log	Log completi di accesso, monitoraggio anomalie, incident response
Continuità operativa	Data center geograficamente distribuiti, piani BCP/DR

Penetration test	Annuale da terze parti indipendenti
Certificazioni	ISO/IEC 27001, SOC 2 Type II, PCI DSS L1
Notifica data breach	Senza indebito ritardo, cooperazione con il Titolare
Sub-processor	Lista pubblica: cloudflare.com/gdpr/subprocessors/ — 30 giorni di preavviso

1.6 Localizzazione dati D1 — Opzione Giurisdizione EU

A partire dal 5 novembre 2025 (Cloudflare D1 Changelog), Cloudflare D1 supporta la **giurisdizione EU**: il database viene creato con il parametro `--jurisdiction=eu` e rimane fisicamente all'interno dell'Unione Europea (data center EU). Questa funzionalità è disponibile anche per i database esistenti tramite migrazione. Si valuta se attivare questa opzione per rafforzare ulteriormente la conformità alla data localization GDPR, pur non essendo obbligatoria in presenza di DPF o SCC validi.

Comando per database con giurisdizione EU:

```
npx wrangler d1 create sindromerenu-db --jurisdiction=eu
```

1.7 Conclusione e azioni raccomandate

#	Azione	Priorità	Note
1	Attendere documentazione Cloudflare richiesta dal DPO	Media	Modificare la DPA con la richiesta di postestazione attuale (titolare autonomo per CDN)
2	Valutare stipula DPA Cloudflare v6.4 per D1 (qualificazione come Responsabile del trattamento) — self-service su dashboard Cloudflare	Alta	Personalizzare la DPA (art. 28 GDPR) — self-service su dashboard Cloudflare
3	Eventualmente creare un nuovo database D1 con giurisdizione EU e migrazione dati se DPA attivo	Bassa	Figura titolare se DPA attivo
4	Aggiornare Privacy Policy aggiungendo Cloudflare come Responsabile (art. 28) la DPA, mantenendo titolare autonomo per CDN/	Alta	Personalizzare la DPA (art. 28 GDPR) — self-service su dashboard Cloudflare

2 QUESITO 2 — Descrizione funzione sendEmail() tramite Resend

2.1 Stato attuale — Funzione implementata ma NON operativa

■ **Importante:** la funzione `sendEmail()` è presente nel codice sorgente (`src/index.tsx`, riga 8594) ma è attualmente **inattiva**. La variabile d'ambiente `RESEND_API_KEY` non è stata configurata in produzione: nessuna email viene trasmessa a Resend né a qualsiasi altro servizio esterno in questo momento. Il DPO può quindi valutare le opzioni prima dell'attivazione, senza impatto sugli interessati.

2.2 Descrizione tecnica della funzione

La funzione è implementata direttamente nel Worker Cloudflare (framework Hono, TypeScript) senza librerie esterne: effettua una chiamata HTTP REST diretta all'API di Resend. Il codice sorgente:

```
async function sendEmail(env, opts: { to?, subject, html }): Promise {
  const key = env?.RESEND_API_KEY
  if (!key) { console.warn("RESEND_API_KEY non configurata"); return }
  const res = await fetch("https://api.resend.com/emails", {
    method: "POST",
    headers: { Authorization: `Bearer ${key}`, "Content-Type": "application/json" },
    body: JSON.stringify({
      from: "Sindrome ReNU Italia ",
      to: [opts.to || "info@sindromerenu.it"],
      subject: opts.subject,
      html: opts.html
    })
  })
}
```

2.3 Flusso dei dati e dati trasmessi a Resend

Il diagramma logico del flusso dati è il seguente:

Fase	Soggetto	Azione	Dato coinvolto
1	Visitatore	Compila form (Contattaci / Lista Attesa)	Nome, email, messaggio, CF
2	Browser → Worker	POST /api/contatti o /api/lista-attesa (HTTP)	Dati form cifrati TLS
3	Worker Cloudflare	Valida, sanifica, hash IP, salva in D1	ip_hash (SHA-256, non reversibile)
4	Worker → Resend API	HTTPS POST a api.resend.com/emails	Nome, email, testo messaggio
5	Resend → Email	Recapita email a info@sindromerenu.it	Stesso payload del punto 4
6	Associazione	Riceve notifica e risponde all'interessato	—

* La riga evidenziata (fase 4) è quella che coinvolge Resend. Attualmente questa fase è **DISATTIVATA** (`RESEND_API_KEY` non configurata).

2.4 Chi è Resend — Documentazione raccolta

Resend è gestita da **Plus Five Five, Inc.** (nome commerciale: Resend), sede legale: 2261 Market Street #5039, San Francisco, CA 94114, USA. È un servizio di invio email transazionali via API REST, fondato nel 2022. Contatto privacy:

privacy@resend.com.

Documento	URL	Stato / Note
DPA (Art. 28 GDPR)	resend.com/legal/dpa	■ Disponibile — pre-firmato da Resend, in vigore al momento della registrazione
Pagina GDPR	resend.com/security/gdpr	■ Completa — include sub-processor, DPF, SCC, retention, breach notification
Privacy Policy	resend.com/legal/privacy-policy	■ Pubblica
Sub-processor list	resend.com/legal/subprocessors	■ Lista aggiornata — preavviso 14 giorni per modifiche
SOC 2 Type II	resend.com/security/soc-2	■ Certificato — report scaricabile dalla dashboard
Certificazione DPF	dataprivacyframework.gov/list	■ CERTIFICATA dal 13 marzo 2025 (EU-U.S. DPF + UK Extension)
DPF Changelog	resend.com/changelog/data-privacy-framework	10 marzo 2025 — Resend certificata DPF

2.5 Analisi GDPR — Qualificazione giuridica di Resend

Aspetto	Analisi	Esito
Qualificazione giuridica	Resend elabora dati personali (nome, email, messaggio) su istruzione del cliente. Dato temporaneo, non archiviato.	■ Responsabile del trattamento è il cliente, non Resend. Art. 28 GDPR
DPA obbligatorio	Sì, art. 28 par. 3 GDPR richiede contratto scritto. Il DPA Resend è già disponibile e pre-firmato.	■ DPA già disponibile e pre-firmato
Trasferimento USA — base giuridica	Resend è certificata EU-U.S. Data Privacy Framework (DPF).	■ DPF / SCC (il DPA include le SCC (MTC))
Dove sono archiviati i dati	Resend archivia tutti i dati negli USA (inclusi contenuto email).	■ Archiviazione negli USA, coperta da DPF + SCC.
Retention	Dati email/log: 30 giorni per piani Free/Pro/Scale. Alla chiusura dell'account, i dati vengono cancellati entro 90 giorni. Backup non cancellati.	■ Retention cancellata entro 90 giorni. Backup non cancellati.
Sub-processor di Resend	Lista pubblica su resend.com/legal/subprocessors. Preavviso 14 giorni per modifiche.	■ 14 giorni per modifiche. Resend rimane responsabile.
Categorie particolari (art. 9)	Il messaggio degli interessati potrebbe contenere dati sulla salute (patologia) o dati biometrici.	■ DPA (patologia) non prevede misure specifiche. Resend non prevede misure.
SOC 2 Type II	Resend è certificata SOC 2 Type II. Report disponibile sulla dashboard.	■ Certificata (con SOC 2 Type II) annualmente da terze parti.
HIPAA	Resend NON è HIPAA compliant e non firma Business Associate Agreement per l'Associazione.	■ Non HIPAA compliant. N/A Agreement.

2.6 Confronto Resend vs Brevo — Alternativa UE

La Privacy Policy attuale menziona **Brevo SAS** (ex Sendinblue) come alternativa "non ancora attiva". Brevo ha sede in Francia (UE) ed eliminerebbe il tema del trasferimento extra-UE. La tabella comparativa:

Criterio	Resend (Plus Five Five, Inc.)	Brevo SAS (ex Sendinblue)
Sede legale	■ ■ San Francisco, USA	■ ■ Parigi, Francia — UE
Archiviazione dati	USA (sempre)	EU (server principali Francia)
Trasferimento extra-UE	Sì — coperto da DPF + SCC	No — trattamento in UE
DPA art. 28 GDPR	■ Pre-firmato, in vigore automaticamente	■ Disponibile — DPA dedicato
DPF certificazione	■ Dal 13/03/2025	N/A — sede UE
SOC 2 Type II	■ Certificato	■ ISO 27001 + SOC 2
Categorie art. 9	DPA non prevede misure specifiche	Verificare DPA Brevo

Attivazione nel sito	Richiede configurazione RESEND_API_KEY. Richiederebbe adattamento codice
Costo	Piano gratuito fino a 3.000 email/mese Piano gratuito fino a 300 email/giorno

2.7 Azioni raccomandate e checklist per il DPO

#	Azione	Responsabile	Priorità	Stato
1	Attendere documentazione Resend inviata dal DPO. De confrontarla con il DPA pubblicato (resend.com/legal/dpa)	DPO	Alta	■ Bloccato
2	Valutare se procedere con Resend (DPF+SCC) o Brevo (UE) prima dell'attivazione	DPO / Tecnico	Alta	■ Decisione aperta
3	Se si sceglie Resend: scaricare il DPA firmato dal dashboard Resend e conservarlo	Tecnico	Alta	■ Pre-attivazione
4	Valutare se il contenuto dei messaggi (dati salute ex art. 9) richiede misure aggiuntive ex art. 9	DPO	Alta	■ DA valutare
5	Aggiornare il Registro dei Trattamenti aggiungendo Resend (o Brevo) come sub-responsabile	DPO	Alta	■ Post-decisione
6	Aggiornare Privacy Policy del sito specificando il provider email attivo	Tecnico	Alta	■ Post-decisione
7	NON attivare RESEND_API_KEY in produzione prima del parere DPO	Tecnico	Critica	■ Bloccato — in attesa DPO

③ RIEPILOGO GENERALE — Adempimenti GDPR in attesa di risposta DPO

La tabella seguente riepiloga tutti gli adempimenti aperti per entrambi i quesiti, in ordine di priorità:

Area	Adempimento	Tipo	Priorità
Cloudflare D1	Valutare stipula DPA Cloudflare v6.4 (qualificazione Responsabile tratt. 28)	Contratto	Alta
Cloudflare D1	Aggiornare Privacy Policy con Cloudflare come Responsabile trattamento	Documento	Alta
Cloudflare D1	Valutare migrazione database con giurisdizione EU (--giurisdizione)	Tecnica	Bassa
Resend / Email	NON attivare RESEND_API_KEY prima del parere DPO	Tecnica	■ Critica
Resend / Email	Decidere: Resend (DPF+SCC) o Brevo (UE) — prima dell'attivazione	Decisione	Alta
Resend / Email	Scaricare DPA firmato Resend (se si sceglie Resend)	Contratto	Alta
Resend / Email	Valutare misure aggiuntive per dati salute ex art. 9 nel contesto sanitario	Valutazione	Alta
Registro trattamenti	Aggiungere Resend/Brevo come sub-responsabile nel registro	Documento	Alta
Privacy Policy	Specificare provider email attivo nella Privacy Policy del sito	Documento	Alta
Cloudflare General	Confermare impostazione giuridica CDN/Pages (titolare automatico)	Verifica	Media

④ FONTI E RIFERIMENTI NORMATIVI

- > **Reg. UE 2016/679 (GDPR):** Art. 13 (informativa), Art. 28 (responsabile), Art. 44-49 (trasferimenti), Art. 32 (sicurezza)
- > **Dec. adeguatezza CE 2023/1795:** EU-US Data Privacy Framework — 10 luglio 2023
- > **Dec. CE 2021/914 SCC:** Clausole Contrattuali Standard — 4 giugno 2021
- > **Cloudflare DPA v6.4:** <https://www.cloudflare.com/cloudflare-customer-dpa/> — eff. 3 aprile 2026
- > **Cloudflare DPF:** <https://www.dataprivacyframework.gov/participant/5666>

- › **Cloudflare D1 giurisdizione:** <https://developers.cloudflare.com/d1/configuration/data-location/>
- › **Cloudflare D1 changelog:** <https://developers.cloudflare.com/changelog/post/2025-11-05-d1-jurisdiction/>
- › **Cloudflare sub-processor:** <https://www.cloudflare.com/gdpr/subprocessors/>
- › **Resend DPA:** <https://resend.com/legal/dpa> — pre-firmato, in vigore al momento registrazione
- › **Resend GDPR:** <https://resend.com/security/gdpr> — incluso DPF, SCC, retention, breach
- › **Resend DPF:** <https://resend.com/changelog/data-privacy-framework-certification> — cert. 13/03/2025
- › **Resend sub-processor:** <https://resend.com/legal/subprocessors>
- › **DPF Registry:** <https://www.dataprivacyframework.gov/list>
- › **Garante Privacy IT:** <https://www.garanteprivacy.it>
- › **EDPB FAQ DPF v2.0:** FAQ EDPB sull'EU-US DPF per imprese europee — 23 gennaio 2026

Sindrome ReNU Italia APSCF 98020680157 — info@sindromerenu.it

Responsabile Tecnico del Sito

Data documento: 24 September 2026

Documento preparato per:

DPO — Sindrome ReNU Italia APS

dpo@sindromerenu.it*Documento riservato — uso interno*